

CVE-2026-31431 — Copy Fail

Linux kernel local privilege escalation • Disclosed April 29, 2026 • CVSS 7.8 HIGH

9 yr

Exposure window

732 B

Exploit size

<1s

Time to root

0

Forensic traces

What happened

A nine-year-old logic bug in the Linux kernel's cryptographic subsystem (`algif_aead`) allows **any unprivileged local user to gain root access** on affected systems. The exploit is deterministic — no race condition, no memory layout guessing, no kernel address leak. It works in under one second and **leaves no trace on disk, in audit logs, or in file integrity scans**.

The vulnerability was discovered by Theori's Xint Code AI security research platform in approximately one hour of automated scanning. It had existed in every major Linux distribution since 2017.

Who is affected

Every Linux system running kernel 4.14 or later with `CONFIG_CRYPTO_USER_API_AEAD` enabled. This includes:

- Red Hat Enterprise Linux 8, 9, and 10
- Ubuntu 20.04, 22.04, 24.04
- Amazon Linux 2023
- SUSE Linux Enterprise
- Any container or Kubernetes workload (page cache is shared with the host)
- NVIDIA Jetson and other edge AI platforms running full-stack Linux

Why this one matters

Most privilege escalation bugs require timing, configuration mistakes, or complex chains. This one does not. It is a straight-line logic flaw: open a socket, splice a file, trigger a crypto operation, 4 bytes land in the page cache of any readable file. Iterate to build arbitrary corruption. Execute the corrupted `setuid` binary. Root.

The page cache angle is what makes this different. The corruption lives in volatile memory. The kernel never marks the page as modified. A reboot destroys all evidence. File integrity tools (AIDE, Tripwire, `rpm -Va`) see a clean file because the on-disk copy was never changed. `auditd` doesn't fire because there is no `write()` syscall to log.

What to do now

1. Check if the module is loadable or compiled in:

```
modinfo algif_aead 2>&1 | head -3
grep CONFIG_CRYPTO_USER_API_AEAD /boot/config-$(uname -r)
```

2. If it's a loadable module, blacklist it immediately:

```
echo "install algif_aead /bin/false" > /etc/modprobe.d/disable-algif-aead.conf
rmmod algif_aead 2>/dev/null
dracut -f    # RHEL/Fedora – rebuild initramfs
```

3. If it's compiled in (=y), you need the kernel patch. In the meantime:

- **MAC policy:** SELinux (RHEL) can block `AF_ALG` socket creation system-wide with a single custom module. AppArmor (Ubuntu/SUSE) can deny it per-profile via `deny network alg,` but requires updating each application profile individually.
- **seccomp policies** in container runtimes can block `AF_ALG` socket creation
- Monitor Red Hat errata, Ubuntu USN, or your vendor's security channel for the kernel update

The blacklist does NOT break: dm-crypt/LUKS, SSH, OpenSSL, kTLS, IPsec, or any standard crypto operation. Only `iwd` (Intel wireless daemon) and `cryptsetup` with non-default algorithms are known to use the `AF_ALG` AEAD interface.

Containers and Kubernetes

Container boundaries do not protect against this vulnerability. The Linux page cache is a host-level resource shared across all namespaces. An attacker inside a container can corrupt the page-cached copy of a `setuid` binary on the host, then trigger its execution.

This is a container escape.

If you run multi-tenant Kubernetes, CI/CD runners, or any system where untrusted code executes in containers: treat this as critical regardless of the “local only” CVSS vector.

Edge and IoT

Edge devices running mainstream Linux kernels (NVIDIA Jetson, industrial gateways, AI inference appliances) are exposed and face compounding risk factors: slow vendor patch cycles, no runtime security monitoring, and the “local” attack vector is more achievable when devices are physically accessible or running exposed services.

Home Users and Consumer Linux Appliances

This is not just a server problem. If you run Linux at home, you may be affected:

- **NAS devices** (Synology, QNAP, TrueNAS) — full Linux kernels, often unpatched for months after disclosure
- **Home routers** running OpenWrt, DD-WRT, or vendor Linux — depends on whether `CONFIG_CRYPTO_USER_API_AEAD` is enabled in the build
- **Raspberry Pi** and single-board computers — Raspberry Pi OS ships mainstream kernels in the vulnerable range
- **Smart home hubs** and media servers running full Linux distributions
- **Steam Deck** and other Linux-based gaming/consumer devices

The home user problem: There is no SELinux, no seccomp policy, no fleet management, and no security team. Home users depend entirely on their vendor shipping a firmware or kernel update — and for many consumer Linux appliances, that update may never come. If your device runs kernel 4.14 *or later* and has the crypto API enabled, the only real mitigation is the vendor patch. **Check your vendor’s security advisories and update as soon as a fix is available.**

References

- Disclosure: [copy.fail](#)
- NVD: [CVE-2026-31431](#)
- CERT-EU Advisory: [2026-005](#)
- Red Hat: Bugzilla [2460538](#), access.redhat.com/security/cve/cve-2026-31431
- Upstream fix: kernel commit `a664bf3d603d` — available in 7.0, 6.19.12, 6.18.22

Jim O'Donnell • Red Hat • RHEL Specialist Solutions Architect